



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Agent Tesla Malware Analysis

Malware Analysis

Classification	TLP:CLEAR
Published	2026-06-01
Version	1.0
Author	Lost Boys Cyber
Report Type	Malware Analysis

TLP:CLEAR | Lost Boys Cyber | Agent Tesla Malware Analysis - Malware Analysis

Published: 2026-06-01 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Sample Metadata
3. Source Review & Confidence
4. Payload Variants and Delivery
5. Infection Chain Analysis
6. Technical Analysis
 - 6.1. Static Analysis Expectations
 - 6.2. Dynamic Analysis Expectations
7. Indicators of Compromise
8. MITRE ATT&CK Mapping
9. Detection Engineering
10. Threat Hunting
11. Triage and Incident Response
12. Validation and Emulation
13. Recommendations
14. References and Refresh Notes

Agent Tesla Malware Analysis

Reconstruction Note

This markdown source was reconstructed from the published PDF in `RAIcoon\_Reports` and then cleaned into a canonical source-built report during analyst-kit standardization. The original editable source was not recovered from the public repository.

1. Executive Summary

Agent Tesla is a long-running .NET spyware and credential-theft Trojan that remains highly prevalent in public malware telemetry. The reconstructed report cites ANY.RUN trend data showing the family ranking second by recent public task volume, and MITRE ATT&CK documents the malware as observed since at least 2014.

The family remains operationally relevant because it solves a simple criminal objective very well: steal credentials and session material from normal user activity. Campaigns commonly use phishing attachments, archives, scripts, and commodity loader chains. Once active, the malware can collect credentials, keystrokes, screenshots, and host information before exfiltrating data over SMTP, FTP, HTTP, or HTTPS.

Confirmed Agent Tesla activity should be treated as credential exposure rather than a one-host nuisance event. Response should prioritize containment, password resets, token and session invalidation, mailbox review, and inspection of outbound exfiltration paths.

2. Sample Metadata

Family summary:

- Family: Agent Tesla
- Type: Spyware Trojan / infostealer / keylogger
- Typical runtime: .NET
- Platform: Windows
- First seen: MITRE lists the software as observed since at least 2014
- Current ranking cited in reconstructed report: #2 on ANY.RUN current tracker with 287 tasks shown in the last seven days
- Common delivery: phishing attachments, archives, scripts, and Office-themed lures
- Confidence: high for core capabilities, medium for rotating infrastructure and campaign-specific indicators

Operational handling summary:

- Treat confirmed infection as a likely credential-compromise event.
- Expect follow-on activity affecting browsers, email clients, FTP clients, VPN clients, and other saved-secret stores.
- Emphasize behavioral hunting over static indicator blocking alone.

3. Source Review & Confidence

Primary analytical basis:

- MITRE ATT&CK software entry S0331 for family taxonomy and technique framing.
- ANY.RUN trend and family overview pages for prevalence and family-level behavioral context.
- Fortinet reporting for campaign structure and delivery-chain detail.
- Additional 2026 reporting from Yazoul for recent activity context.

Confidence assessment:

- High confidence in the general family capabilities because the claims are consistent across ATT&CK and vendor reporting.
- Medium confidence in specific infrastructure and campaign indicators because Agent Tesla operations rotate delivery paths and exfiltration endpoints frequently.

- Medium confidence overall because the editable source was reconstructed from a published PDF and then normalized into markdown.

What should carry most decision weight:

- The family's credential-theft behavior.
- The likelihood of phishing or archive-driven delivery.
- The importance of SMTP, FTP, and user-writable execution telemetry.

4. Payload Variants and Delivery

Agent Tesla is typically distributed through phishing and commodity loader chains. Public reporting referenced by the report shows archive and script-based delivery including RAR, TGZ, VBS, BAT, PowerShell, and executable payloads. Operators often blend malicious steps with legitimate email or hosting infrastructure, which complicates simple domain-based blocking decisions.

Ecosystem notes:

- The malware persists in criminal operations because it is reliable, easy to deploy, and compatible with low-cost phishing operations.
- The delivery chain is often more variable than the underlying collection goals.
- Defenders should expect attachment-driven, archive-driven, or script-assisted execution paths.

5. Infection Chain Analysis

Representative infection chain:

1. A user opens a phishing attachment, archive, or lure document.
2. A script, loader, or executable launches Agent Tesla or a staging component.
3. The malware profiles the host and collects local account and system information.
4. Persistence may be established through registry Run keys or startup-folder placement.
5. Credentials, keystrokes, screenshots, browser data, mail-client data, and FTP or VPN credentials may be harvested.
6. Data is exfiltrated over SMTP, FTP, HTTP, or HTTPS.

Why this matters:

- Multiple parts of the chain may look mundane in isolation.
- The strongest detections often come from the combination of user-writable execution, credential-store access, and outbound application-layer exfiltration.

6. Technical Analysis

Key behaviors:

- Keylogging and user-interaction capture
- Browser, email-client, FTP-client, VPN, and application credential harvesting
- System information discovery
- Data staging and encryption or encoding before exfiltration
- SMTP and FTP exfiltration, which are especially important telemetry points
- Persistence through common autorun locations

6.1. Static Analysis Expectations

When a binary is available, review:

- .NET metadata, assembly names, resources, and obfuscator fingerprints
- SMTP, FTP, HTTP/S, Telegram, or panel configuration values
- Hardcoded email accounts, recipient addresses, ports, credentials, and server names
- Strings for browser, mail-client, VPN, FTP, and application credential targets

- Anti-analysis process names, VM checks, and AV-evasion logic
- Persistence strings and startup paths

6.2. Dynamic Analysis Expectations

Capture:

- Parent-child process lineage from attachment, archive, or script to payload
- Host, network, wireless, and user enumeration behavior
- Access to browser stores, mail clients, FTP clients, VPN clients, and application credential locations
- Outbound SMTP or FTP sessions, including process identity and destination
- Registry Run key or startup-folder writes
- Screenshot, keylogging, clipboard, and form-grab behavior

7. Indicators of Compromise

The supporting IOC file is intentionally conservative and focuses on durable analytic pivots rather than volatile campaign infrastructure.

Representative IOC classes in `iocs.csv`:

- Family identifier: Agent Tesla
- Exfiltration protocol pivots: SMTP and FTP
- Credential-target classes: browser credentials and email credentials

Operational guidance:

- Treat behavior as higher-value than raw infrastructure indicators.
- Use protocol and process context rather than blocking on family name alone.
- Expect infrastructure churn and campaign-specific variance.

8. MITRE ATT&CK Mapping

Mapped ATT&CK techniques from the supporting artifact:

- T1087.001 - Account Discovery: Local Account
- T1082 - System Information Discovery
- T1547.001 - Registry Run Keys / Startup Folder
- T1056.001 - Keylogging
- T1113 - Screen Capture
- T1555 - Credentials from Password Stores
- T1071.001 - Application Layer Protocol: Web Protocols
- T1071.003 - Application Layer Protocol: Mail Protocols
- T1048 - Exfiltration Over Alternative Protocol

Associated software:

- S0331 - Agent Tesla

Interpretation:

- This ATT&CK set captures the family's emphasis on credential access, user surveillance, persistence, and application-layer exfiltration.

9. Detection Engineering

Detection priorities:

- Direct SMTP or FTP from non-standard executables in user-writable paths
- Script or archive-driven parentage followed by .NET payload execution
- Access to browser, mail-client, FTP-client, and VPN credential stores
- Registry Run key or startup-folder persistence for suspicious binaries

- User-profile executables making unusual outbound connections

Supporting sidecar artifacts:

- `detections/kql/agent-tesla-hunt.txt`
- `detections/sigma/agent-tesla-suspicious-smtp-ftp-user-writable.txt`
- `detections/yara/agent-tesla-like-dotnet-credential-theft.txt`

Recommended analytic themes:

- Parent-child chains involving archive extractors, script hosts, or Office-adjacent launchers
- User-writable execution followed by credential-store access
- SMTP or FTP network activity from processes that are not approved mail or automation tools
- Multiple identity stores accessed by the same process in a short interval

10. Threat Hunting

Hunt objectives:

- Find user-writable executables that initiate SMTP, FTP, HTTP, or HTTPS sessions outside expected software baselines.
- Trace from phishing or archive delivery to downstream script or .NET execution.
- Identify access to browser profiles, local state, mail-client stores, FTP configuration, or VPN artifacts.
- Compare suspicious outbound sessions against known-good backup, business automation, and mail applications.

Useful hunt pivots:

- Script hosts spawning .NET payloads
- Processes running from `AppData`, `Temp`, or `Users\Public`
- Browser or mail-store access followed by external network communication
- Repeated outbound authentication or small-batch exfiltration patterns

11. Triage and Incident Response

Immediate response steps:

7. Isolate the affected host and preserve the EDR timeline.
8. Collect the phishing email, attachment hash, process tree, autoruns, network connections, and credential-store access events.
9. Reset user passwords and rotate credentials saved in browsers, mail clients, FTP clients, VPN clients, and developer tools.
10. Revoke sessions and OAuth tokens.
11. Review mailbox rules and outbound mail abuse.

Identity and data-exposure analysis should explicitly review:

- Browser credentials, cookies, and local state
- Email credentials and forwarding-rule abuse
- FTP, VPN, RMM, and remote-access credentials
- Screenshots, keylogs, and any captured business data

The goal is to answer not just "was the host infected" but "which identities, sessions, and business data may now be exposed."

12. Validation and Emulation

Use controlled lab tests for direct SMTP or FTP from user-writable paths and for credential-store access simulation. Validate false positives against approved mail, backup, and automation tools before production blocking.

Safe validation checks:

- Confirm your telemetry can tie outbound sessions to the originating process.
- Confirm registry Run-key and startup-folder changes are visible to your SIEM or EDR.
- Confirm browser, mail-client, and FTP artifact access is captured where your tooling supports it.

- Validate hunts against known-good administrative, backup, and business applications.

13. Recommendations

Critical - SOC - 24 hours

- Alert on direct SMTP or FTP from non-standard executables in user-profile paths.

High - IAM - 24 to 72 hours

- Rotate credentials after confirmed infection and review related session exposure.

High - Email Security - 7 days

- Block or detonate archive and script attachments that lead to executable payloads.

Medium - Endpoint Engineering - 30 days

- Restrict script execution and unknown .NET binaries from user-writable paths.

Programmatic recommendations:

- Treat Agent Tesla as an identity-exposure problem first.
- Build detections around behaviors rather than only static malware markers.
- Make mailbox review, browser credential review, and token revocation part of the standard response flow.

14. References and Refresh Notes

- ANY.RUN Malware Trends Tracker
- <https://anyrun.de/malware-trends/>
- ANY.RUN Agent Tesla overview
- <https://any.run/malware-trends/agenttesla/>
- MITRE ATT&CK Agent Tesla S0331
- <https://attack.mitre.org/software/S0331/>
- Fortinet Agent Tesla multi-stage campaign analysis
- <https://www.fortinet.com/blog/threat-research/unmasking-agent-tesla-deep-dive-into-multi-stage-campaign>
- Fortinet Agent Tesla malware attack report
- https://filestore.fortinet.com/fortiguard/outbreak_alert/agent_tesla_malware_attack/report.pdf
- Yazoul Agent Tesla April 2026 report
- <https://www.yazoul.net/malware/agent-tesla/reports/2026-04-23/>
- ANY.RUN Malware Trends Report 2025
- <https://any.run/cybersecurity-blog/malware-trends-2025/>

Intelligence gaps:

- SMTP and FTP indicators are often operator-specific and short-lived.
- Fileless campaigns may leave fewer disk artifacts.
- Public samples may overrepresent noisy phishing operations.
- Credential-exposure scope depends heavily on user behavior and saved secrets, not just malware capability.